

CPA Cybersecurity Audit Report

Conducted By: Locket Cybersecurity

Contributors: Max Smith, Domingo Contreras, Ruhama Tesfa, Kevin Mei, Janelys Graciano, Kaylie Mei

Table of Contents

[Section 1: Data Storage Security](#)

[Section 2: Data Backup Options](#)

[Section 3: Antivirus Services](#)

[Section 4: Software Update Management](#)

[Section 5: Password Management](#)

[Section 6: Ad Blockers](#)

[Section 7: Email/Phishing Safety](#)

[Bibliography](#)

1. Data Storage Security

Overview

Ensuring the security of data storage is crucial for any medical practice particularly when handling Electronic Protected Health Information (ePHI). This section outlines considerations and security controls for popular cloud storage services. Specifically, Google Workspace and Dropbox with a focus on following the NIST cybersecurity framework and maintaining HIPAA compliance.

HIPAA Compliance

When utilizing cloud storage services for any data containing ePHI, it is a requirement under HIPAA to have a Business Associate Agreement (BAA) in place with the service provider. This agreement legally binds the service provider to appropriately safeguard ePHI and report any data breaches.¹

NIST Cybersecurity Guidance

The NIST Cybersecurity framework emphasizes three main things when it comes to data storage. Firstly, it takes a risk-based approach to protecting electronic Protected Health Information (ePHI). Organizations should evaluate vulnerabilities, and implement reasonable and appropriate security measures to mitigate those risks. Second, the guidance suggests implementing safeguards required by the HIPAA security rule including Administrative safeguards like access controls to ePHI, security awareness and training, and contingency planning. Physical safeguards are also important like password locked devices to prevent unauthorized intrusion.²

Google Workspace

To use Google workspace in a HIPAA-compliant manner for storing ePHI, the practice must review and accept [Google's Business Associate Agreement \(BAA\)](#). This is done through the Google Workspace Admin Console. Further resources: [Deploy 2-Step Verification \(video\)](#), [viewing log event data](#).

Review and accept the HIPAA Business Associate Amendment

1. [Sign in](#) with a *super administrator* account to the Google Admin console.
If you aren't using a super administrator account, you can't complete these steps.
2. Go to Menu ≡ > @ [Account](#) > [Account settings](#) > [Legal and compliance](#).
Note: Under this section is where you can also access a copy of the BAA once signed.
3. Go to the **Security and Privacy Additional Terms** section.
4. Click **Google Workspace/Cloud Identity HIPAA Business Associate Amendment** to review the amendment.

¹ Office for Civil Rights (OCR), 2016

² Marron, 2024

5. Click **Review and Accept** and answer all three questions to confirm that you are a HIPAA covered entity.
6. To accept the HIPAA BAA, click **OK**.

Dropbox

Dropbox offers a BAA for its paid team plans. In particular Dropbox Business, Business Plus, and Enterprise Plans. Consumer or free versions of Dropbox are not suitable for ePHI.³ Similar to Google Workspace, simply purchasing a plan isn't sufficient. The administrator must sign the BAA and monitor the security controls to ensure HIPAA compliance. Recommended security configuration would involve setting up granular sharing permissions, enabling two-factor authentication for users, and regularly [viewing access logs](#).

Sign a Business Associate Agreement for your Dropbox Team Account

1. [Log in](#) to dropbox.com with your admin credentials.
2. Click **Admin Console**.
3. Click **Settings**.
4. Under **Account**, click **Team profile**.
5. Under **Advanced**, click **Set up BAA**.
6. Review and complete the agreement.

Get a copy of the signed BAA:

Once you've signed the BAA, a copy downloads to your Dropbox account. If you need to download the agreement again:

1. [Log in](#) to dropbox.com with your admin credentials.
2. Click **Admin Console**.
3. Click **Settings**.
4. Under **Account**, click **Team profile**.
5. Under **Advanced**, click **Download BAA**.

How to require two-factor authentication for team member

1. [Log in](#) to dropbox.com with your admin credentials.
2. Click **Admin Console**.
3. Click **Settings**.
4. Under **Authentication**, click **2-factor authentication**.
5. Toggle the setting next to **2-factor authentication** from Optional to **Required**.
6. Click **Save changes**.

³ Team, 2024

Enhanced Dropbox Security Controls

Beyond the initial setup of a BAA, administrators can enforce stricter protocols to protect files, monitor activity, and manage access. Implementing these controls your organization can significantly enhance its data security within Dropbox, ensuring that access to sensitive information is deliberately managed and monitored. Here are some options to better enhance your Dropbox security posture:

Review and Manage External Application Access: It is critical to periodically review and remove unnecessary third-party applications that have access to your team's Dropbox accounts. This minimizes the risk of data exposure through old or insecure applications.

1. [Log in](#) to dropbox.com with your admin credentials.
2. Navigate to the **Admin console**.
3. Click **Settings** in the left sidebar.
4. Under the "Apps" section, select **App permissions**.
5. Here you can see a list of connected applications. To block one, check the box next to the app and click **Block**.
6. It is recommended to set the "Default permission for apps" to **Block**, which prevents team members from connecting new, unapproved apps. You can then add exceptions for specific approved applications.

Secure Shared Links with Expiration Dates and Passwords: to prevent indefinite access to sensitive data, all links should be shared with both a password and an automatic expiration date. This ensures that even if a link is exposed, it cannot be accessed without the password and becomes inactive after a set period of time. *Note: This functionality is available on Dropbox Professional, Standard, Advanced, Business, Business Plus, and Enterprise plans.*

1. From your Dropbox account, hover over the file or folder you wish to share and click **Share**.
2. In the pop-up window, select **Settings**.
3. Depending on the level of access you want to provide, click either **Link for editing** or **Link for viewing**.
4. Next to **Require password**, toggle the switch to "On" and enter a strong, unique password.
5. Next to **Expiration**, toggle the switch to "On" and select a date for the link to expire.
6. Click **Save**.

Enforce Viewer-Only Access for Documents and Files: when sharing information that does not require modification by the recipient, always use "view-only" permissions. This prevents accidental or unauthorized changes to the original documents.

1. Hover over the file or folder you want to share and click the **Share** button.
2. If a link has already been created, click **Settings**. If not, create one.

3. Ensure that the link setting is designated as **Link for viewing**. This allows recipients to view and comment but not edit the content.
4. You can further restrict downloads for this link by toggling **Disable downloads** to "On" in the same settings menu.
5. Click **Save**.

2. Data Backup Options

Overview

This section outlines recommendations for reliable data backup to help protect the organization's information from loss. It focuses on business-grade versions of top-rated consumer products that offer data protection, encryption, reporting and alerts, and access controls and permissions. Additionally, these solutions provide centralized management and can be tailored to organizational needs.

The Importance of Data Backup

Data backup is an essential element of information security and business continuity planning. Since no system is flawless, having a reliable backup in place is imperative. Effective data backup enables organizations to recover quickly and maintain operations during unexpected events.⁴ The following are key benefits of implementing a data backup system:

- **Protection Against Data Loss:** Backups serve as a safety net against data loss caused by unexpected events such as human error or cyberattacks.⁵
- **Support for Regulatory Compliance:** Many industry regulations, including HIPAA, GDPR, and NIST SP 800-53, emphasize the importance of data availability and integrity. Backups can help meet these compliance requirements by ensuring that sensitive data can be restored in a timely and verifiable manner.⁶
- **Alignment with Cybersecurity Frameworks:** The NIST Cybersecurity Framework identifies "Recover" as a core function, which data backup is central to. The rapid restoration of systems and data allows backup solutions to reduce the impact of cyber attacks and support business continuity planning as recommended by leading frameworks.

Data Backup Recommendations

Note: These recommendations are based on PCMag's article "[The Best Backup Software and Services for 2025](#)"⁷. The software solutions were ranked based on performance and ratings across multiple categories. We have compiled a list of the recommended options that are most suitable for your organization.

1. [IDrive](#)

IDrive offers free local backup, unlimited devices per account, fully encrypted, fast upload speeds, excellent value, and inexpensive add-on for backups of Microsoft and Google accounts. With support for every major operating system and no limit on the number of devices you can

⁴ Hastings, 2025

⁵ Techno, 2024

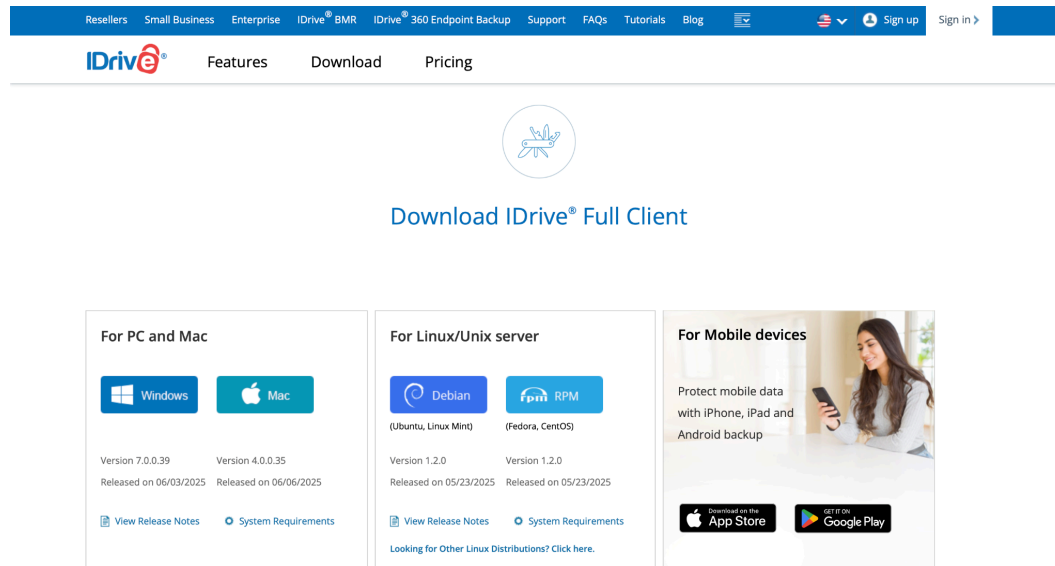
⁶ Rotlevi, 2025

⁷ PCMag, 2025

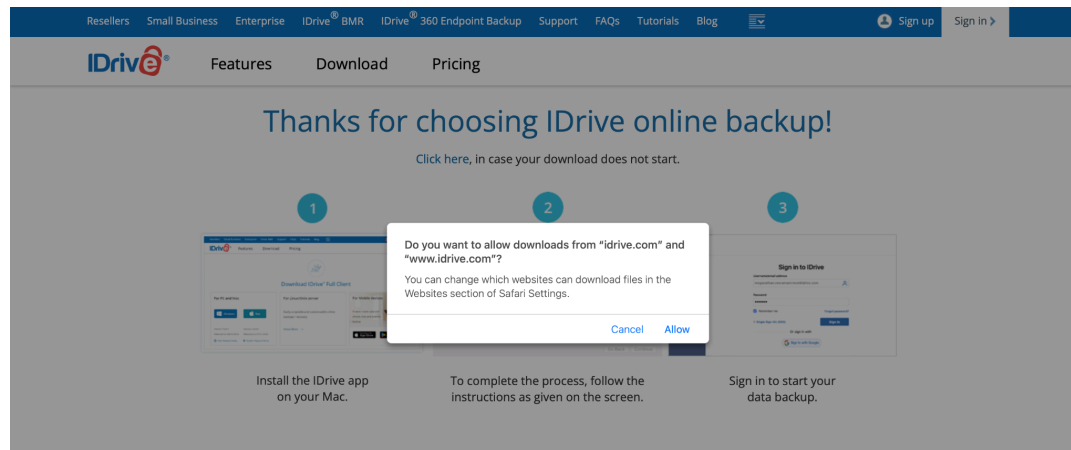
back up, IDrive is great for anyone with a lot of data spread across multiple devices. The low price also makes IDrive perfect for anyone who wants to back up multiple devices without breaking the bank.

Installation:

1. Go to <https://www.idrive.com/online-backup-download>.



2. Download the iDrive Installer.



3. Run the Installer.



2. [Backblaze](#)

Backblaze offers unlimited storage, supports multi-factor authentication and private encryption keys, ability to back up or restore via mailed drive, and fast upload speeds. It's ideal for novice

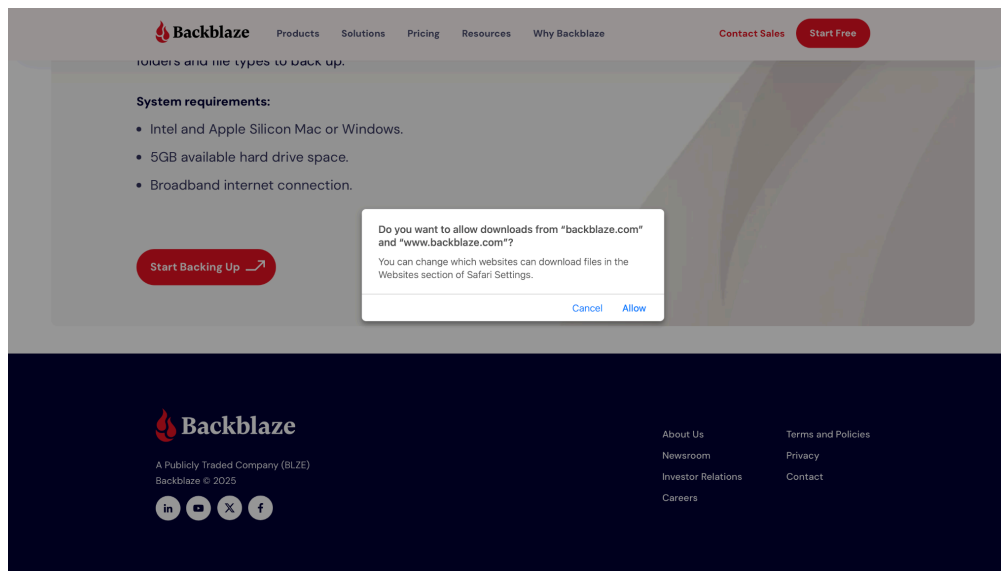
users who want a full backup of a single Windows or macOS computer without a lot of complicated options.

Installation:

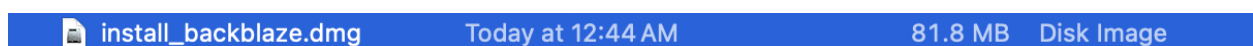
1. Go to <https://www.backblaze.com/status/business-install>.



2. Download the iDrive Installer.



3. Run the Installer.



3. [Acronis True Image](#)

Acronis offers more backup tools than competing services, local and cloud backup options, full disk image backup and restore, file syncing, and protects against ransomware and malicious URLs. It has the best combination of backup and security features. One thing to note is that Acronis now only sells Cyber Protect Home as a subscription.

Disclaimer for Data Backup Options: To support the protection and continuity of your systems, we've identified these three data backup solutions based on PCMag's "[The Best Backup Software and Services for 2025](#)." This source evaluates tools based on their reliability, performance, and suitability for various organizational needs. These backup solutions are designed to simplify and automate the process of safeguarding critical data, helping to ensure recoverability in the event of loss, corruption, or cyberattacks. While these tools offer strong advantages in data protection and recovery, they are most effective when integrated into a comprehensive security and continuity strategy. We recommend reviewing each provider's website to assess features, compatibility, and pricing based on your organization's size and infrastructure. Our goal is to offer well-vetted options that can enhance your resilience and streamline your backup operations.

3. Antivirus Services

Overview

This section outlines recommendations for antivirus software for protecting the organization's device. The selections are based on evaluations from reputable sources, focusing on products that offer robust protection, and features that are appropriate for a smaller organization. We've looked at "business" versions of highly-rated consumer products that provide centralized management and can be tailored for organizational needs.

The Importance of Antivirus Software

Antivirus software is a critical component of a comprehensive cybersecurity strategy. While no security tool is considered infallible, modern antivirus solutions offer a significant upgrade in protection against a wide array of cyber threats when compared to relying on minimal or no specialized security software. The tooling is designed to detect, prevent, and remove malicious software (malware) such as viruses, ransomware, spyware, and other types of harmful programs. Implementing reputable antivirus software generally helps to:

- **Protect against exploits:** Antivirus software provides an essential layer of defense against malware that attempts to exploit vulnerabilities, including those that are unpatched or newly discovered "zero-day" vulnerabilities.⁸ By focusing on malicious code protection, these tools can help to prevent unauthorized access and system compromise that generally results from these exploits.
- **Alignment with Cybersecurity Frameworks:** Cybersecurity frameworks like the NIST framework, directly mention the use of antivirus software. The "Protect" function within the CSF highlights the necessity of implementing measures like antivirus to safeguard assets. These tools are vital for protecting data, which could be compromised by a cybersecurity attack. Furthermore, controls against malicious code (antivirus software) is mandated in NIST Special Publication (SP) 800-53, "Security and Privacy Controls for Information Systems and Organizations,"⁹ to protect information systems like those that contain ePHI.

Antivirus Software Recommendations

Note: These recommendations are based on PCMag's "[The Best Antivirus Protection for 2025](#)"¹⁰ article. The article evaluates a wide range of available softwares, and from their top picks these options appear suitable for a small organization. We have sourced "business" products that are adjacent to those on the list that may be most suitable to your organization.

⁸ IBM, 2023

⁹ NIST, 2020

¹⁰ Rubenking, 2025

1. Bitdefender Antivirus Plus / Bitdefender GravityZone Business Security
 - a. PCMag often highlights Bitdefender products for their excellent scores in independent lab tests and their comprehensive feature sets. While "Antivirus Plus" is a consumer product, Bitdefender's **GravityZone Business Security** provides centralized management and security features tailored for business environments, which would be appropriate for your organization. These products are typically praised for effective malware protection and a range of security-enhancing components.
 - b. [Bitdefender GravityZone Onboarding](#)
2. Norton 360 Deluxe / Norton Small Business
 - a. Norton products frequently receive Editors' Choice awards from PCMag. They are known for strong virus and malware protection and often include a broad suite of security tools such as a VPN, password manager, and online backup. For an organization, **Norton Small Business** offerings would provide the necessary multi-device protection and business-focused support.
 - b. [Norton Installation and Setup](#)
3. Webroot SecureAnywhere Antivirus / Webroot Business Endpoint Protection
 - a. Webroot is noted by PCMag for its extremely light system impact and fast scans. It employs a cloud-based approach to malware detection and offers features like identity theft protection. The **Webroot Business Endpoint Protection** solutions extend this lightweight, fast, and effective protection to business environments, offering manageability for multiple users.
 - b. [Webroot Setup](#)

Disclaimer for Antivirus Software: We've selected these three antivirus solutions based on their high ratings and reviews in PCMag's 'The Best Antivirus Protection for 2025'. This source is known for its thorough testing and evaluation of security software. While these products (and their business-specific versions) are recognized industry leaders, it's important to remember that no security tool is infallible. However, they offer a significant upgrade in protection against a wide array of cyber threats compared to having minimal or no specialized security software. We recommend visiting their respective websites to explore the business solutions, compare features relevant to your needs (like centralized management or multi-device coverage), and consider any available trials to choose the one that best fits your organization's operational requirements and budget. Our aim is to provide you with strong, reputable options to make an informed decision.

4. Software Update Management

Overview

This section addresses the critical practice of software update and patch management, an essential part of a resilient cyber security posture. It will detail the reasons why maintaining up-to-date software is essential, particularly in a healthcare setting handling ePHI. We will outline relevant guidelines by prominent authoritative bodies, and then present recommendations for tooling based on highly-rated consumer and small business products.

Importance of Update Management

Keeping all software current and up to date is one of the most effective ways of protecting against cyber threats and ensuring system stability. The failure to do so can produce significant risks. There are a few key areas that emphasize this importance:

- **Addressing Security Vulnerabilities:** The primary reason to update software is to patch security flaws. Malicious actors seek to exploit vulnerabilities in outdated software to gain unauthorized access to systems. Good practice involves enabling automatic updates.
- **Maintain HIPAA Compliance:** A failure to keep software current is considered a HIPAA violation. This is because updates generally address vulnerabilities that potentially could expose data. To effectively manage risk, and ensure compliance, software patches should be applied as soon as they are available.¹¹
- **NIST Recommendations:** The NIST emphasizes diligent patch management in its Special Publication 800-40 Revision 4, "Guide to Enterprise Patch Management Planning,"¹² highlighting a few key points. Keeping software up to date reduces the overall attack surface, as it naturally limits the number of exploitable vulnerabilities. It allows for greater system resilience avoiding compromises that could disrupt operations. Patch management is also an example of proactive defense which involves preventing incidents by addressing weaknesses before they can be exploited by attackers.

Patch Management Software Recommendations

These recommendations are based on TechRadar's "[Best patch management software of 2025](#)".¹³ The article reviews various tools to help automate the crucial process of keeping software updated.

1. Avast Business Patch Management
 - a. According to TechRadar, Avast Business Patch Management is offered as an add-on to Avast's antivirus products. The service supports patching for thousands of applications from over 100 vendors, including major ones like Adobe, Google, and Microsoft (Windows and applications). Users can set custom rules for how the update process

¹¹ Alder, 2014

¹² Souppaya & Scarfone, 2022

¹³ Williams, 2024

works across their network, defining scan times, patch deployment schedules (immediate, scheduled, or manual), and exclusions for specific applications or vendors.

- b. [Avast Business Patch Management Setup](#)
- 2. ManageEngine Patch Manager Plus
 - a. TechRadar lists ManageEngine Patch Manager Plus as a comprehensive patch management solution that supports Windows, macOS, and Linux, as well as many third-party applications. It offers features like automated patch deployment, vulnerability assessment, and reporting, which can be highly beneficial for ensuring systems are secure and up-to-date.
 - b. [ManageEngine Setup](#)
 - c. [ManageEngine Setup - Third Party Source](#)
- 3. Automox
 - a. Automox is highlighted by TechRadar for its cloud-native platform that automates patching for Windows, macOS, Linux, and third-party software. It emphasizes ease of configuration and the ability to enforce patching policies across all devices, regardless of location, which is useful for maintaining security hygiene.
 - b. [Automox Agent Installation](#)

Disclaimer for Software Updater Tools: To help maintain the security of your systems by keeping software current, we've identified these three patch management tools based on TechRadar's 'Best patch management tools in 2025' review. This source evaluates tools on their ability to automate and manage updates across various platforms. These tools are designed to simplify the critical task of patching, which helps protect against known vulnerabilities. While they offer significant advantages in automation and security, they are most effective as part of a broader security strategy. We encourage you to visit their websites, understand their feature sets and pricing for an organization of your size, and see which one best integrates with your current IT environment and operational preferences. Our goal is to equip you with effective options to manage software updates efficiently.

5. Password Managers

Overview & Importance

Passwords are a core part of maintaining a good security posture. “Cyber-attacks often begin with a compromised password that is used to gain initial access to an electronic information system” ([HHS.gov](https://www.hhs.gov)). Securing your practice and patients’ information through good password protection looks like using password managers, Multi-Factor Authentication, and a strong master key. Password managers are a useful tool for creating and securely storing passwords, allowing you to generate and use strong, unique passwords with ease. Multi-Factor Authentication is highly recommended to be used in addition to password managers to add an extra layer of defense against attackers through an additional verification beyond passwords.

Password Manager Recommendations

Following recommendations from [TotalHIPAA](#) and [BlockSurvey](#), and after a comprehensive evaluation of their features, some of the top password managers for HIPAA compliance are listed below for your consideration. Please note that the prices for password managers fluctuate, and the prices below were current as of May 27, 2025.

The three recommended options for password managers, Bitwarden, Keeper, or Dashlane, all share these features:

- Operate zero-knowledge security, so the providers cannot access your account information or passwords
- Built-in tools to generate secure passwords and to identify weak passwords
- Allows syncing of password data between an unlimited number of devices
- Support two-factor authentication
- Strong encryption through industry-standard encryption such as AES-256 bit encryption
- Passwords are stored securely in an encrypted database, password vault

Bitwarden

- Can send encrypted texts and files to anyone, with or without a Bitwarden account
- Email alias generator to protect your identity when using online services/subscriptions
- Built on an open-source model, increasing transparency and allowing for public auditing
- [Business cost](#): \$4-6 per user per month
- [Download Instructions](#) & Setup Instructions:
 1. [Contact Bitwarden](#) about signing a Business Associate Agreement with the plan that works for you
 2. Select bitwarden.com for US Cloud storage, enter your email address, and start free trial

Start your 7-day Teams trial

Boost team productivity with secure password storage, sharing, and autofill from any device and location

Email

Preferred server location

☐ Get advice, announcements, and research opportunities from Bitwarden in your inbox. [Unsubscribe](#) at any time.

By continuing, you agree to the [Terms of Service](#) and [Privacy Policy](#)

- ✓ **Easy secure sharing:** share logins and other items with departments, teams, and individuals
- ✓ **Intuitive user management:** enhance security practices across your team with an easy-to-use admin portal
- ✓ **Fast autofill:** save time and increase productivity by auto-filling usernames and passwords
- ✓ **Migrate quickly:** use comprehensive import options

3. Confirm email

bitwarden

Verify your email address below to finish creating your account.

If you did not request this email from Bitwarden, you can safely ignore it.

4. Create a master password ([recommended guidelines below](#))

Set a strong password

Finish creating your account by setting a password

New master password (required)

Important: Your master password cannot be recovered if you forget it! 12 character minimum.

Confirm new master password (required)

Master password hint

If you forget your password, the password hint can be sent to your email. 0/50 character maximum.

☒ Check known data breaches for this password

5. Import passwords stored at other locations (ex. Chrome, Edge) by either downloading & uploading them or by copying and pasting them in

Import data

Destination

Vault (required)
My vault

Folder
-- Select a folder --

Select this option if you want the imported file contents moved to a folder

Data

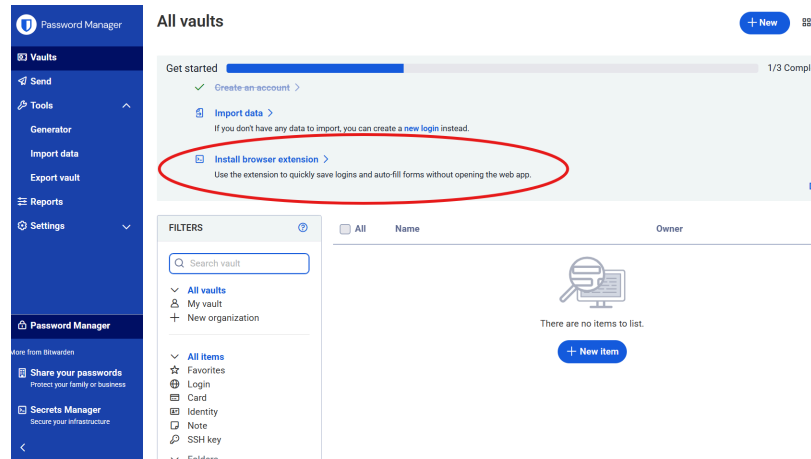
File format (required)
Chrome (csv)

Chrome (csv) instructions
See detailed instructions on our help site at <https://bitwarden.com/help/import-from-chrome/>

Select the import file
 No file chosen

or copy/paste the import file contents

6. Would recommend installing a browser extension for ease of use



Dashlane

- Built for customer ease of use
- Cost: \$8-20+ per month per user
- Download instructions

Keeper

- Two-factor authentication using biometrics called Keeper DNA
- Collaborations made easier through team folders & management
- Cost: \$2-3.75+ per user per month
- Download Instructions

Disclaimer: Keep in mind that no security system can stop all attacks and these password managers are not infallible. However, using these recommended password managers and Multi-Factor Authentication will significantly boost your security posture and help keep your passwords secure. We recommend exploring these options, choosing the one that is the best fit for your practice, and signing a Business Association Agreement (BAA) with your chosen provider.

Creating A Master Key

While password managers generate secure passwords through their platforms for your accounts, you are still responsible for creating a master password that serves as the key to your entire account. As described in Keeper's article, "[How To Create a Strong Master Password You'll Remember](#)," and information from [NIST's publication](#), the following are good practices to follow when selecting a password:

- **Unique:** Your master password must be unique and not be the same or similar to any other password you use for any other accounts, whether personal or professional. If your master key is compromised, all the information in your password manager could be at risk. Avoid simple words or information easily linked to you (like names, dates, or common phrases).
- **Length:** Your password should be a minimum of 16 characters long; the longer the better.

- **Complexity:** In your password, include uppercase letters, lowercase letters, numbers, and symbols.
- **Guessability:** Do not include any information that directly relates to you or your practice in any way. Your Master Password should be unpredictable and not easily guessed by someone who knows you or could research you.
- **Memorability:** Your Master Password should ideally not be stored anywhere digitally or written down. To help with remembering it, consider using secure passphrase techniques or acronyms hidden within your password. For example, using a memorable phrase like "I like ice cream" to create a password like "i_1ik3|c3Cr3@m\$!" can make it both strong and memorable.

Tools

- You can use a reputable password strength tester, such as [Bitwarden's Password Strength Checker](#), to get an idea of how strong a hypothetical password is. These tools process the check locally in your browser and do not send your password anywhere.
- Have I Been Pwned is a well-known website used to check to see if your information has been in breaches. You can check for things like your [email](#) or [password](#), and it will tell you how many breaches it has been a part of or if your information has been exposed. When checking or your email, it will also include information about what breaches, if any, and what was exposed.

Disclaimer: No single security measure is foolproof. Even the strongest master password can face threats like sophisticated phishing attempts. However, by following these guidelines for creating and protecting your master password, you will dramatically improve the security of your password managers and their sensitive information.

6. Ad Blockers

Overview

This section details ad blockers, technologies that prevent ads from being displayed on the web. When you think of cybersecurity and potential threats, advertisements likely aren't the first things that come to mind, but as we will explain, ad blockers can be integral to maintaining a good cybersecurity posture. What follows is an explanation of the types of cyber threats that ads can present, followed by some recommendations for ad blocking software.

Potential Benefits of Ad Blockers

There are many reasons why organizations decide to install ad blocking software. Online advertisements may seem benign, but they can present risks¹⁴, which include but are not limited to:

- **Malvertising:** Malware and phishing links are concealed as legitimate advertisements.
- **Phony Buttons and Links:** Advertisements are designed to appear as though they are a central part of the site hosting them (usually by appearing as a download button of some sort), but really lead to unrelated software downloads or viruses in the worst case. The software may collect user data and send it to third parties, for example.



- **Invasions of Privacy:** Even if advertisements don't outright lead to malware, ad networks can collect a lot of user data such as the exact pages visited on a website and the exact set of interactions on a website. Lots of personal information can be inferred from someone's browsing data. If you're curious about what ad networks can see about you, we would highly encourage you to visit the Electronic Frontier Foundation's [Cover Your Tracks](#), where you can test your browser with a tracking company.

Note that even if your organization chooses not to adopt ad blocking software as a standard, many of the above risks can be mitigated by education and attention to detail. By reading this report, you are taking a fantastic step towards being able to recognize malicious advertisements. Note that many such advertisements share characteristics with email phishing attacks, which will be covered in a later section. Remember - always think twice before you click anything!

¹⁴ Clements, 2024

Ad Blocker Recommendations

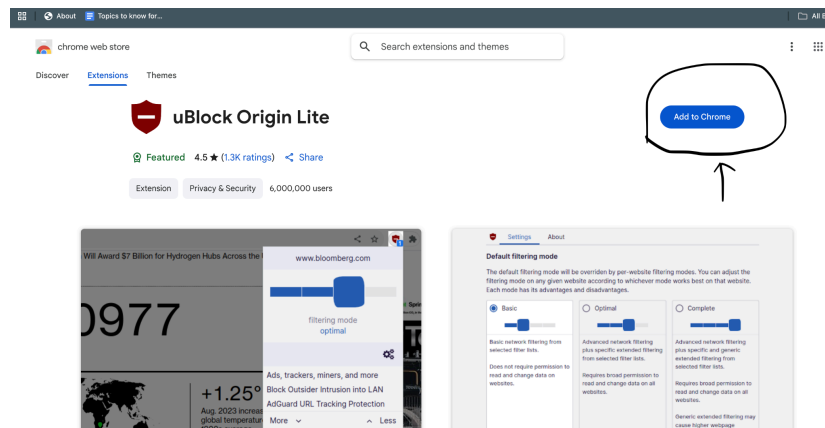
Fortunately, most ad blockers are cost-free, at least at the base tier. They are also usually simple to install, often as browser extensions. We have compiled a list of some of the most effective ad blockers (as reported by cybersecurity experts and by actual users) for your consideration.

Note: These recommendations are based on PCMag's "[The Best Ad Blockers for 2025](#)"¹⁵ article.

1. *The workhorse* - uBlock Origin - Known for extremely high reliability and customizability. Unfortunately, the full version is not available for Chrome, but [uBlock Origin Lite](#) receives very good reviews from users.
2. *If privacy is your main concern* - [Privacy Badger](#) - Especially effective for blocking trackers that collect user data, and created by a nonprofit that views privacy as extremely important. PCMag reports that Privacy Badger is less effective at blocking ads in general than uBlock Origin.
3. *Want simplicity and ease of use?* - [Ghostery](#) - Reportedly has the best interface/ease of installation, and is effective at blocking various types of ads. Less customization than the previous two recommendations.

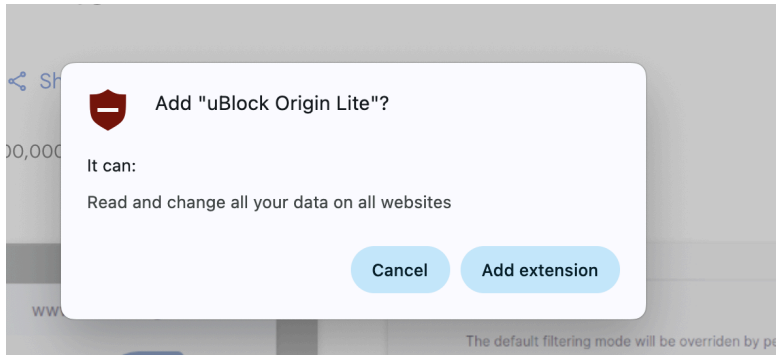
Each of the psychiatrists in your practice might prioritize different aspects of adblocking software. As these are all free browser extensions, each psychiatrist can install the software of their choosing.

Sample Installation (uBlock Origin Lite)

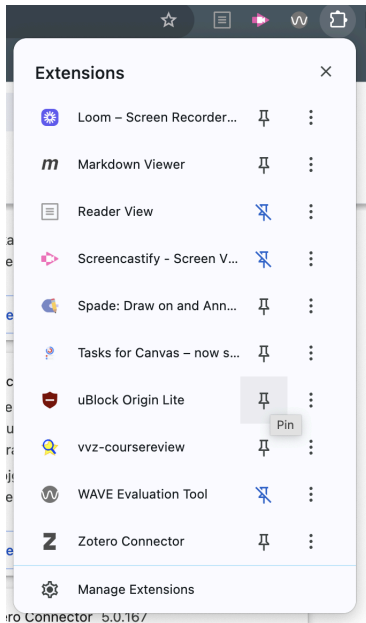


Navigate to the link and click the “add to Chrome” button

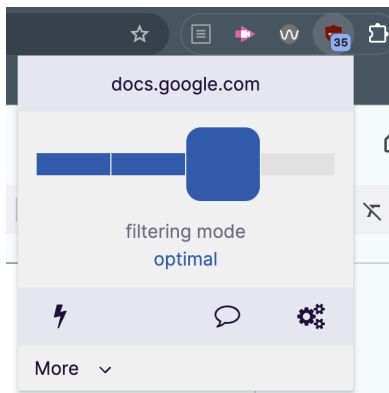
¹⁵ Key, 2025



Click the “Add extension” button when prompted



Hover over the extensions logo and click the pin next to the uBlock Origin row



Hover over the uBlock logo to change the mode and settings

7. Email/Phishing Safety

Overview

This section details the pervasive threat of phishing, a common form of cyberattack that can have severe consequences for a psychiatric practice, including unauthorized access to ePHI, and significant financial or reputational damage. Understanding the nature of phishing, recognizing its various forms, and knowing where to find updated information about phishing attacks can be crucial for protecting your practice and patients.

Understanding Phishing

Phishing is a prevalent type of social engineering that involves manipulation techniques that exploit human error to gain private information, access, or valuables. Phishing specifically takes advantage of digital communication, most commonly through email, to trick individuals into revealing sensitive information. Attackers often craft phishing messages to appear as if they originate from a trusted person or legitimate organization such as a bank or a government agency. The Cybersecurity and Infrastructure Security Agency (CISA) defines phishing as an attempt by a cyber threat actor to lure a victim into providing sensitive information or network access by posing as a trustworthy entity. These messages can lead unsuspecting recipients to act against their better judgment, potentially causing them to bypass security procedures and compromise sensitive data.¹⁶

Common Types of Phishing Attacks

Phishing attacks come in various forms, each tailored to deceive targets in slightly different ways. Recognizing these different tactics is the first, and most powerful step in defending against them.¹⁷

- **Email Phishing (General Phishing):** This is the most common form, involving broadly distributed emails that appear to come from legitimate organizations. They often contain urgent requests, warnings, or enticing offers to lure recipients into clicking malicious links or opening infected attachments.
- **Spear Phishing:** This is a more targeted attack. Attackers research their victims (individuals or specific roles within an organization) and craft personalized messages that appear highly relevant and legitimate. CISA notes that spear phishing emails often include key information about the target to increase believability.
- **Whaling:** A specific type of spear phishing that targets high-profile individuals within an organization, such as executives or administrators (often referred to as "big phish" or "whales"). The goal is usually to steal highly sensitive company information, authorize fraudulent high-value wire transfers, or gain high-level system access.

¹⁶ CISA, 2025

¹⁷ Check Point, 2020

- **Smishing (SMS Phishing):** This involves phishing attacks conducted via SMS (text) messages. Attackers send text messages containing deceptive links or urgent requests, hoping the recipient will click the link on their mobile device or call a fraudulent number.
- **Vishing (Voice Phishing):** In vishing attacks, perpetrators use voice calls (sometimes using VoIP to spoof caller ID) to trick individuals into divulging sensitive information. They might impersonate IT support, bank representatives, or government officials.
- **Angler Phishing:** This type of phishing occurs on social media platforms. Attackers create fake customer service accounts for well-known companies or impersonate public figures to trick users into revealing login credentials or personal information.

Recognizing a Phishing Attempt

Being able to recognize a phishing attempt is the most effective way to counteract it. Attackers often rely on their messages appearing legitimate to deceive recipients. By carefully inspecting emails and messages, you can spot the warning signs of a phishing attack. Here are several common indicators¹⁸:

- **Check the Sender's Address:** Carefully examine the sender's email address. Phishing emails often come from addresses that try to mimic a legitimate organization but are slightly different, perhaps with a misspelling or an unusual domain (e.g., info@google.net instead of info@google.com)
- **Hover over Links:** Before clicking on any link, hover your mouse over it to see the actual destination URL. If the URL looks suspicious or doesn't match the context of the email, **DO NOT** click it.
- **Look for Typos and Grammatical Errors:** Legitimate communications from official organizations are typically well-written and professionally edited. Phishing emails often contain spelling mistakes, poor grammar, and awkward phrasing.
- **Sense of Urgency:** Phishing messages frequently try to create a sense of urgency or panic such as claiming your account has been compromised or will be closed if you don't act immediately. This tactic is designed to make you act quickly without thinking.

Staying Current with Phishing Attacks

To stay updated on the latest phishing trends and defense strategies, the following resources are highly recommended.

- [Google's Phishing Quiz](#) - a tool that you can use or share that illustrates just how difficult it can be to identify these attacks.
- [Phishing.org](#) reports on the latest phishing trends and shares free resources that can help reduce phishing attacks.
- The [Anti-Phishing Working Group \(APWG\)](#) is a non-profit group of multidisciplinary security experts that publishes a quarterly report on phishing trends.

¹⁸ CISA, 2025

- [Have I Been Pwned](#) - a resource which allows you to check if your personal information has been compromised in data breaches, like your email and password. This is a great reason to change your password, particularly if it has been exposed!

Bibliography

Alder, S. (2014, December 24). *Patch and Update Computer Software or Face a HIPAA Sanction*. The HIPAA Journal.

<https://www.hipaajournal.com/patch-and-update-software-or-face-a-hipaa-sanction/>

BlockSurvey. (2023, October 18). *HIPAA Compliant Password Managers*. BlockSurvey.io.

<https://blocksurvey.io/hipaa-compliant-tools/hipaa-compliant-password-managers>

Check Point. (2020, November 3). What Is Phishing? *Check Point Software*.

<https://www.checkpoint.com/cyber-hub/threat-prevention/what-is-phishing/>

CISA. (2025). *Recognize and Report Phishing*. www.cisa.gov.

<https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>

Clements, C. "The Argument for Enterprise-Wide Ad Blocking." CISO Global, 25 Apr. 2024,

www.ciso.inc/blog-posts/argument-for-enterprise-wide-ad-blocking/.

IBM. (2023, June 2). *Zero-day*. ibm.com. <https://www.ibm.com/think/topics/zero-day>

Key, K. "The Best Ad Blockers for 2025." *PCMag*, PCMag, 8 Apr. 2025,

www.pcmag.com/picks/best-ad-blockers?test_uuid=02LIF0iWKsilxYTJVF8uH5y&test_variant=B. Accessed 2 June 2025.

Marron, J. (2024). Implementing the Health Insurance Portability and Accountability Act

(HIPAA) Security Rule: *National Institute of Standards and Technology, Special Publication 800(66r2)*. <https://doi.org/10.6028/nist.sp.800-66r2>

NIST. (2020). Security and Privacy Controls for Information Systems and Organizations.

Security and Privacy Controls for Information Systems and Organizations, 5(5).

<https://doi.org/10.6028/nist.sp.800-53r5>

NIST. (2020, March). *Digital Identity Guidelines, Authentication and Lifecycle Management* (NIST Special Publication 800-63B). <https://doi.org/10.6028/NIST.SP.800-63b>

Office for Civil Rights (OCR). (n.d.). *Security Rule*. HHS.gov.
<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

Office for Civil Rights (OCR). (2016, October 6). *Cloud Computing*. HHS.gov.
<https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html>

Rubenking, N. (2025, May 22). *The Best Antivirus Software for 2025*. PCMag; PCMag.
https://www.pcmag.com/picks/the-best-antivirus-protection?test_uuid=02LIF0iWksilxYTJVF8uH5y&test_variant=B

Souppaya, M., & Scarfone, K. (2022). Guide to Enterprise Patch Management Planning: *Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology, SP 800-40(4)*. <https://doi.org/10.6028/nist.sp.800-40r4>

Team, O. (2024, January 31). *Is Dropbox HIPAA Compliant? A Guide*. OhMD.
<https://www.ohmd.com/is-dropbox-hipaa-compliant/>

TotalHIPAA. (2024, March 15). *Password Manager Reviews for HIPAA Users*. TotalHIPAA.com. <https://www.totalhipaa.com/password-manager-reviews-hipaa-users/>

Williams, M. (2024, December 13). *Best Patch Management Software of 2025*. TechRadar Pro; TechRadar. <https://www.techradar.com/best/best-patch-management-tools>

Hastings, J. (2025, January 8). *The importance of data backup and recovery plans for businesses*. Choice Bank.
<https://bankwithchoice.com/the-importance-of-data-backup-and-recovery-plans-for-businesses/>

Technotc. (2024, December 16). What is Data Backup and Recovery? A Comprehensive Guide -
Techno Advantage. *Techno Advantage*.

<https://technoadvantage.com/what-is-data-backup-and-recovery/>

Rotlevi, S. (2025, May 31). *Cloud Compliance 101: Regulations and best practices*. wiz.io.

<https://www.wiz.io/academy/cloud-compliance-fast-track-guide>

Breaking down the NIST Cybersecurity Framework: Recover. (n.d.).

<https://www.cybersaint.io/blog/nist-function-recover>

PCMag. (2025, January 8). *The best backup software and services for 2025*. PCMAG.

<https://www.pcmag.com/picks/best-backup-services>